



Firewall Configuration Kali (Core)

Olubukola Omotayo
Coding Dojo Cybersecurity Boot Camp
2nd December 2023

Assignment Submission

As part of the Security Operations Center (SOC) for Company X, you are tasked with setting up the firewall to fit certain situations.

For the upcoming scenarios, you will need to research how to set up rules in UFW (a quick google search will suffice), **Once you've finished a scenario, reset the rules back to default before starting on the next.** Then, repeat this process until you are finished with all scenarios.

Assignment Solution:

Company X is overjoyed to have Wi-Fi! They are encouraging all employees to begin researching digitally rather than only through books. Allow HTTP, HTTPS, and SSH traffic.

Hence the UFW rules below will be added:

- HTTP (Port 80)
- HTTPS – (Port 443)
- SSH – (Port 22)

```
(kali㉿kali)-[~]
└─$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

(kali㉿kali)-[~]
└─$ sudo ufw allow 80/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
└─$ sudo ufw allow 443/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
└─$ sudo ufw allow 22/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
└─$
```

- **"Rule Added":** This message indicates that the rule was successfully added to the IPv4 (Internet Protocol version 4) configuration.
- **"Rule Added (v6)":** This message indicates that a similar rule was added to the IPv6 (Internet Protocol version 6) configuration.

```
(kali㉿kali)-[~]
$ sudo ufw status verbose
[sudo] password for kali:
\\Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
80/tcp ALLOW IN Anywhere
443/tcp ALLOW IN Anywhere
22/tcp ALLOW IN Anywhere
80/tcp (v6) ALLOW IN Anywhere (v6)
443/tcp (v6) ALLOW IN Anywhere (v6)
22/tcp (v6) ALLOW IN Anywhere (v6)

(kali㉿kali)-[~]
$
```

- Reset the rules back to default before starting on the next.

```
(kali㉿kali)-[~]
$ sudo ufw reset
Resetting all rules to installed defaults. Proceed with operation (y|n)? y
Backing up 'user.rules' to '/etc/ufw/user.rules.20231130_031403'
Backing up 'before.rules' to '/etc/ufw/before.rules.20231130_031403'
Backing up 'after.rules' to '/etc/ufw/after.rules.20231130_031403'
Backing up 'user6.rules' to '/etc/ufw/user6.rules.20231130_031403'
Backing up 'before6.rules' to '/etc/ufw/before6.rules.20231130_031403'
Backing up 'after6.rules' to '/etc/ufw/after6.rules.20231130_031403'

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: inactive

(kali㉿kali)-[~]
$ sudo ufw enable
Firewall is active and enabled on system startup

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

(kali㉿kali)-[~]
$
```

Company X just heard that they can lower their costs by having all employees access the same computer for storing their data! Deny all incoming traffic except for remote desktop access.

Hence the UFW rules below will be added:

- Allow Remote Desktop (Assuming Port 3389 for RDP)
- Deny All Incoming Traffic (Default Policy)
- Allow Outgoing Traffic (Default Policy)

```
(kali㉿kali)-[~]
$ sudo ufw allow 3389/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
3389/tcp ALLOW IN Anywhere
3389/tcp (v6) ALLOW IN Anywhere (v6)

(kali㉿kali)-[~]
$
```

- Reset before proceeding to the next scenario:

```
(kali㉿kali)-[~]
$ sudo ufw reset
Resetting all rules to installed defaults. Proceed with operation (y/n)? y
Backing up 'user.rules' to '/etc/ufw/user.rules.20231130_032355'
Backing up 'before.rules' to '/etc/ufw/before.rules.20231130_032355'
Backing up 'after.rules' to '/etc/ufw/after.rules.20231130_032355'
Backing up 'user6.rules' to '/etc/ufw/user6.rules.20231130_032355'
Backing up 'before6.rules' to '/etc/ufw/before6.rules.20231130_032355'
Backing up 'after6.rules' to '/etc/ufw/after6.rules.20231130_032355'

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: inactive

(kali㉿kali)-[~]
$ sudo ufw enable
Firewall is active and enabled on system startup

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

(kali㉿kali)-[~]
$
```

Company X has realized that maybe what they've been doing is not the most secure. They'd like to do some more research into cybersecurity and have put you in charge! Configure a machine that would lure a hacker in to attack. You want to tempt an attacker with an easy access route. For this, you will need to run a vulnerable FTP server, an outdated vulnerable web server and telnet. All other traffic incoming should be denied.

- Allow FTP (port 21)
- Allow Web Server (Port 80)
- Allow Telnet (Port 23)
- Deny traffic incoming (Default policy)

```
(kali㉿kali)-[~]
$ sudo ufw allow 21/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
$ sudo ufw allow 23/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
$ sudo ufw allow 80/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
21/tcp ALLOW IN Anywhere
23/tcp ALLOW IN Anywhere
80/tcp ALLOW IN Anywhere
21/tcp (v6) ALLOW IN Anywhere (v6)
23/tcp (v6) ALLOW IN Anywhere (v6)
80/tcp (v6) ALLOW IN Anywhere (v6)

(kali㉿kali)-[~]
$
```

Now that Company X has been taught what a vulnerable web server looks like, they want you to create a more secure web server for their company. Go ahead and configure your firewall rules to enable such a machine's traffic and then write about why you chose the ports/protocols that you did. Feel free to compare it to the last scenario's firewall configuration!

In configuring a more secure web server for Company X, I'll consider best practices for web server security and implement firewall rules accordingly. The goal is to allow only necessary traffic while minimizing potential attack vectors. I'll focus on using HTTPS for secure communication and ensure that unnecessary services and ports are restricted.

Here's a simple set of UFW (Uncomplicated Firewall) rules for a more secure web server:

- **Allow Incoming Traffic on Port 22 (SSH):**
This rule allows SSH traffic on port 22 for secure remote administration.
- **Allow Incoming Traffic on Port 443 (HTTPS):**
Port 443 is used for secure HTTPS traffic. This is the standard port for encrypted communication.
- **Deny All Other Incoming Traffic (Default Policy):**
This sets the default policy for incoming traffic to deny, ensuring that only explicitly allowed traffic is permitted.
- **Allow Outgoing Traffic (Default Policy):**
This sets the default policy for outgoing traffic to allow, ensuring that the server can initiate outgoing connections.

```

(kali㉿kali)-[~]
$ sudo ufw allow 22/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
$ sudo ufw allow 443/tcp
Rule added
Rule added (v6)

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), disabled (routed)
New profiles: skip

To Action From
--
22/tcp ALLOW IN Anywhere
443/tcp ALLOW IN Anywhere
22/tcp (v6) ALLOW IN Anywhere (v6)
443/tcp (v6) ALLOW IN Anywhere (v6)

(kali㉿kali)-[~]
$

```

Disable:

```

(kali㉿kali)-[~]
$ sudo ufw disable
Firewall stopped and disabled on system startup

(kali㉿kali)-[~]
$ sudo ufw status verbose
Status: inactive

(kali㉿kali)-[~]
$

```


A sentence or two describing what the security advantage or disadvantage may be for the firewall configuration.

The firewall configurations are designed to establish robust security measures, safeguarding against potential threats that could compromise the Confidentiality, Integrity, and Availability of operations.

However, it's important to strike a balance, as excessively tightening incoming connections may inadvertently disrupt access to legitimate resources vital for company operations.

List each protocols port number and main use.

Protocol	Port Number	Usage
HTTP	80	Hypertext Transfer Protocol (Unencrypted Web)
HTTPS	443	Hypertext Transfer Protocol Secure (Encrypted Web)
FTP	21	File Transfer Protocol
SSH	22	Secure Shell (Secure Remote Administration)
Telnet	23	Telnet (Unencrypted Remote Access)
SMTP	25	Simple Mail Transfer Protocol (Email sending)
DNS	53	Domain Name System (Name resolution)
DHCP	67/68	Dynamic Host Configuration Protocol (IP assignment)
TFTP	69	Trivial File Transfer Protocol
SNMP	161/162	Simple Network Management Protocol (Network monitoring)
POP3	110	Post Office Protocol version 3 (Email retrieval)
IMAP	143/993	Internet Message Access Protocol (Email retrieval)
LDAP	389/636	Lightweight Directory Access Protocol (Directory services)
SMB	445	Server Message Block (File and printer sharing)
RDP	3389	Remote Desktop Protocol (Remote desktop access)
NTP	123	Network Time Protocol (Time synchronization)
SNMP Trap	162	SNMP Trap (Sending notifications in SNMP)

Find below a table listing well-known ports along with whether they are commonly associated with unencrypted or encrypted protocols:

Port Number	Protocol	Usage	Encryption
20	FTP	File Transfer Protocol (Data)	Unencrypted
21	FTP	File Transfer Protocol (Control)	Unencrypted
22	SSH	Secure Shell (Remote Administration)	Encrypted
23	Telnet	Telnet (Remote Access)	Unencrypted
25	SMTP	Simple Mail Transfer Protocol (Email)	Unencrypted
80	HTTP	Hypertext Transfer Protocol (Web)	Unencrypted
110	POP3	Post Office Protocol version 3 (Email)	Unencrypted
143	IMAP	Internet Message Access Protocol (Email)	Unencrypted
443	HTTPS	Hypertext Transfer Protocol Secure (Web)	Encrypted
989	FTPS	FTP Secure (Alternative for FTP)	Encrypted
990	FTPS	FTP Secure (Alternative for FTP)	Encrypted
993	IMAPS	IMAP Secure (Secure Email Retrieval)	Encrypted
995	POP3S	POP3 Secure (Secure Email Retrieval)	Encrypted
3389	RDP	Remote Desktop Protocol	Encrypted

December 16th, 2023

Instructor Kevin's comment below triggered some deeper thinking:

- **Would there be any situation (other than a honeypot) that you would need to use insecure ports?**

Using insecure ports, especially for services that involve sensitive information or communication, is generally discouraged due to security reasons. Insecure ports can expose systems to various risks, such as unauthorized access, data interception, and manipulation. However, there might be situations where the use of insecure ports is necessary, though these situations are limited and should be approached with caution. Here are a few scenarios where the use of insecure ports might be considered:

1. Legacy Systems:

In some cases, legacy systems or outdated applications may not support secure protocols. Organizations might temporarily use insecure ports as they transition to more secure solutions.

2. Development and Testing Environments:

In non-production environments, such as development or testing, insecure ports may be used for convenience. However, it's crucial to ensure that this practice doesn't carry over into production settings.

3. Internal Networks with Controlled Access:

In highly controlled internal network environments where security is less of a concern, organizations may use insecure ports for specific services. This, however, assumes that the internal network is well-protected, and access is tightly controlled.

4. Debugging and Troubleshooting:

In some cases, system administrators or developers might temporarily open insecure ports for debugging or troubleshooting purposes. This should only be done for a short duration and with proper monitoring.

5. Interoperability Issues:

In scenarios where different systems or applications need to communicate, but there are interoperability issues with secure ports, using insecure ports might be a temporary workaround. The focus should be on resolving the compatibility issues.

6. Limited Impact on Security:

In situations where the information being transmitted is not sensitive, and there are additional security measures in place, using insecure ports might be deemed acceptable. However, such cases are rare, and it's important to carefully assess the risks involved.

It's important to note that even in these situations, using secure communication protocols whenever possible is highly recommended. If insecure ports are used, organizations should have a clear plan and timeline for transitioning to more secure configurations.

Regular security assessments and audits should also be conducted to identify and address any potential vulnerabilities.

Overall, the default best practice is to use secure communication protocols and to avoid insecure ports wherever possible.